Switchboard — Solution

Category: WEB | Points: 300 | Author: Jerit3787

Overview

A VoIP management API with extensive endpoints. A `/docs` page lists all public endpoints but omits the unlisted `/debug/config` which leaks the JWT signing secret. Players must fuzz to find it, then forge an admin JWT to access `/api/admin/flag`.

Steps

1. Hit `GET /` — points to `/docs`.
2. Visit `/docs` — comprehensive API reference listing public endpoints.
3. Login as `operator:operator123` via `POST /api/login` — get a JWT with `role: user`.
4. Explore all listed endpoints — `/api/voicemail`, `/api/recordings`, `/api/config`, `/api/metrics`. All return interesting data that leads nowhere.
5. Directory fuzz to discover unlisted endpoints — find `GET /debug/config`.
6. `/debug/config` returns the JWT secret: `PBXAdmin$ecretK3y!2026-issabel`.
7. Also discover unlisted `GET /api/admin/flag` and `GET /api/admin/system`.
8. Forge a JWT with `{"user": "admin", "role": "admin"}` signed with the leaked key.
9. `GET /api/admin/flag` with `Authorization: Bearer <forged_token>` — returns the flag.

Red Herrings

- `/api/voicemail` — contains file paths like `/var/spool/asterisk/voicemail/...` that look like path traversal candidates but are just static strings.
- `/api/recordings` — similar file paths that look exploitable but aren't.
- `/api/config` — returns detailed application config (SIP settings, feature flags) but NOT the JWT secret.
- `/api/metrics` — Prometheus metrics endpoint with system stats that are purely informational.
- `/docs` — deliberately omits `/debug/config` and `/api/admin/*` to force enumeration.

Flag

```
gctf26{jwt_m0r3_l1k3_ju5t_w1ng1ng_th3_t0k3ns}
```